

IAM Training Program – Day 2

Enterprise Security & Risk Management (ESRM)





- Identity and Access Governance (IAG)
- Directory Services
- Role Management

Identity and Access Governance (IAG)



1. IAG Overview and Introduction

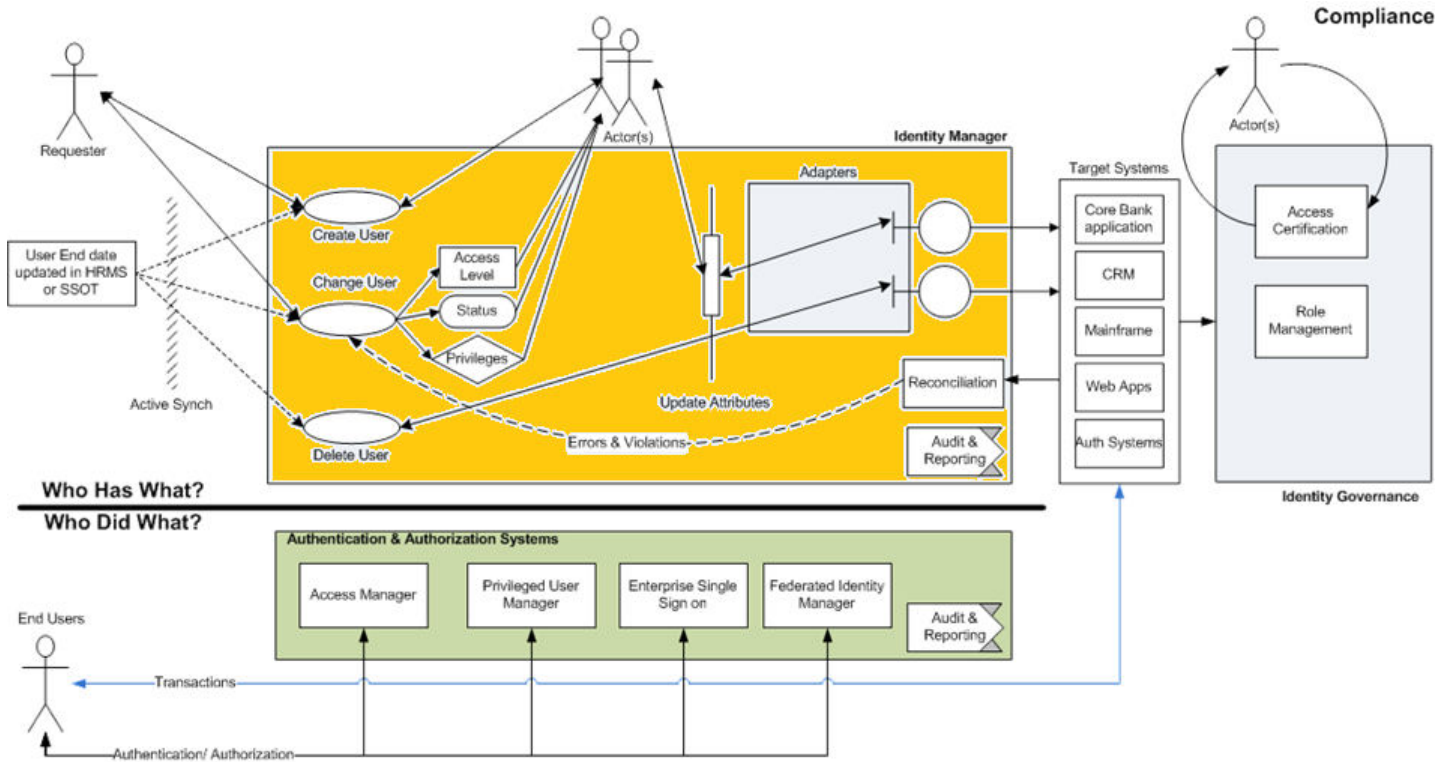


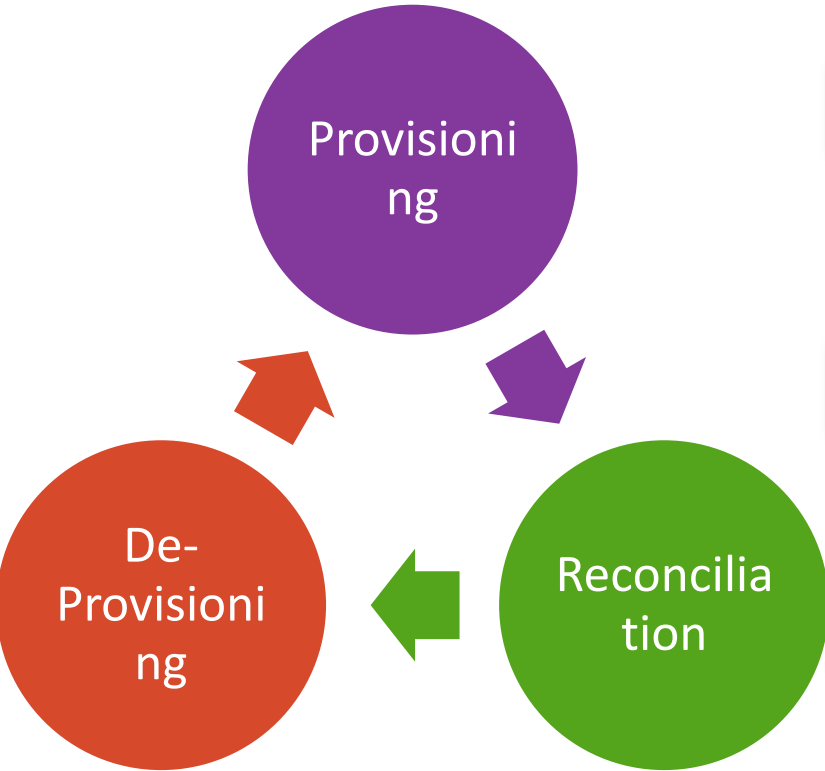
What is Identity and Access Governance (IAG) ?



Identity governance is the policy-based centralized orchestration of user identity management and access control. Identity governance helps support enterprise IT security and regulatory compliance.

IAG - Session Context





User account **Provisioning** is a business process for creating and managing access to resources in an information technology (IT) system

Reconciliation is the process of synchronizing accounts between the managed resource and the Identity Manager Server

User account **De-provisioning** is a business process for deleting and freeing access to resources in an information technology (IT) system

2. User Life Cycle Management



User Life Cycle Management



Employee goes on Long Leave



Contract Completion



Account Lockout



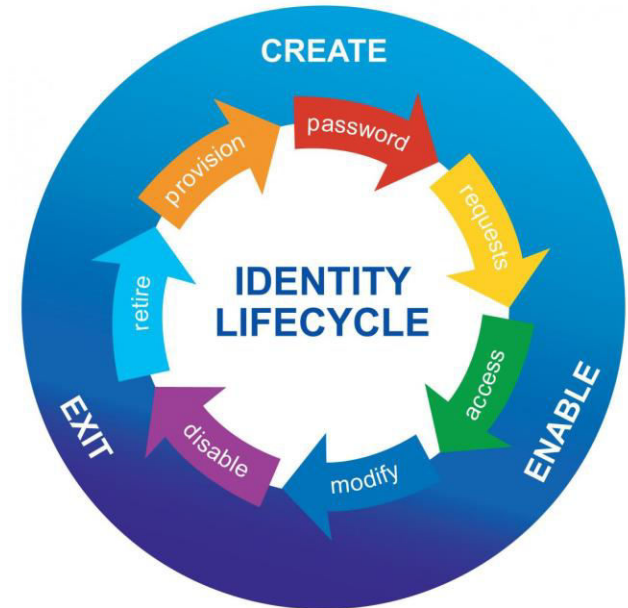
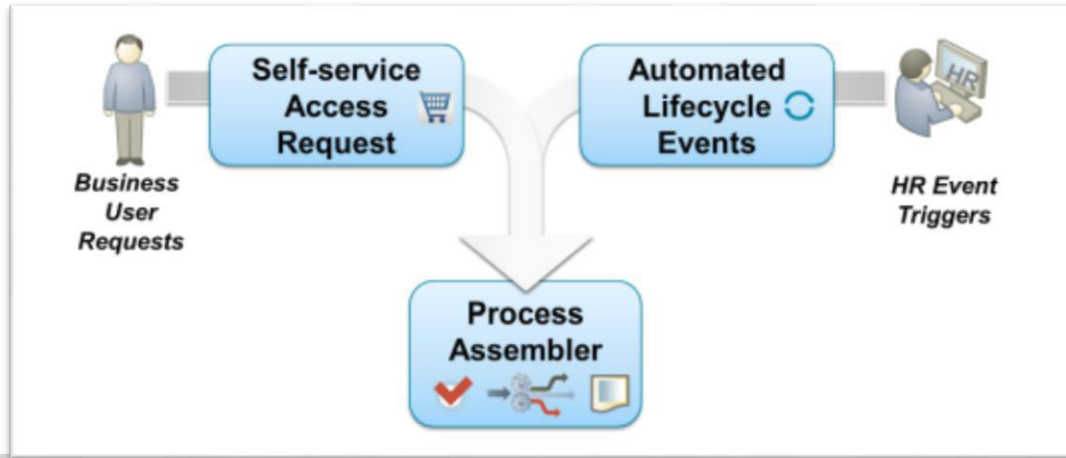
Retirement



Switching Depts

User Life Cycle Management

- **Lifecycle Event Management** – Automatically detects changes in the organization (e.g., joiners, movers, leavers) and proactively aligns access to the “desired state”
- **Self-service Request** – Business-friendly “shopping cart” guides users through self-service access request processes, including creating and editing identities, requesting roles and entitlements, and managing passwords
- **Process Assembler** – Dynamically generates forms and risk-based workflows to support access request processes



3. Password Management

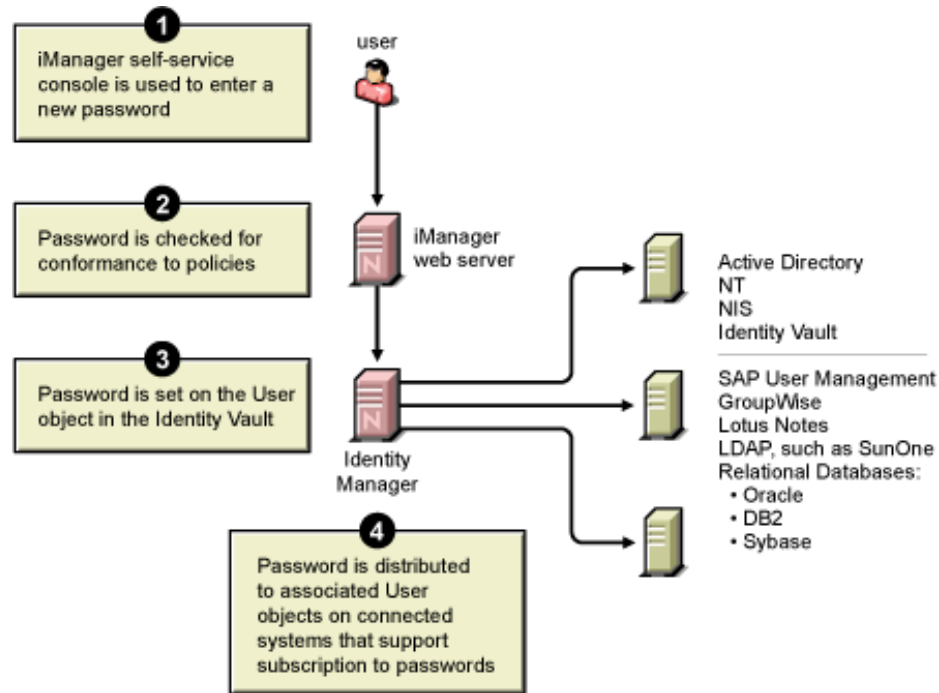


Self Password Reset



IAM Solution offer Password Self Service functionality (like change password, retrieve forgotten password or reset password) in order to increase productivity of the User and decrease load on helpdesk

Password Synchronization

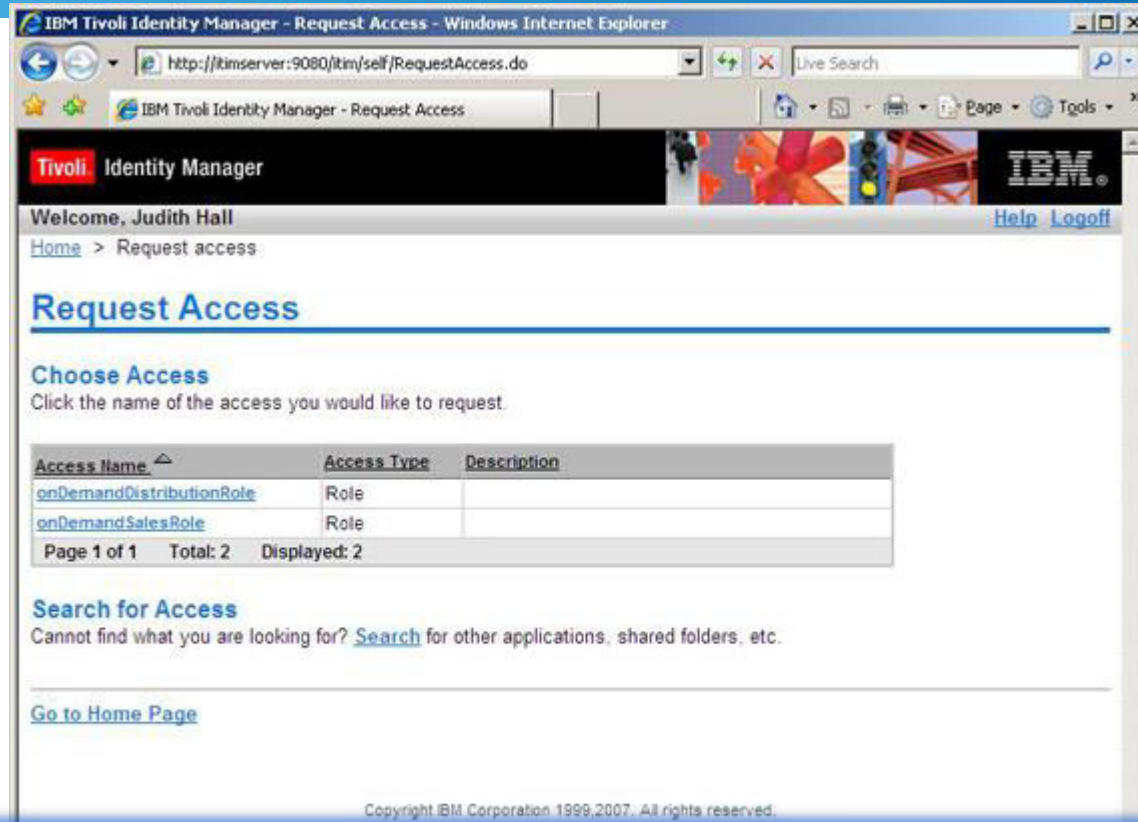


IAM Solution offers **Password synchronization** - a process which maintains a single user password across all multiple IT systems

4. Access Request

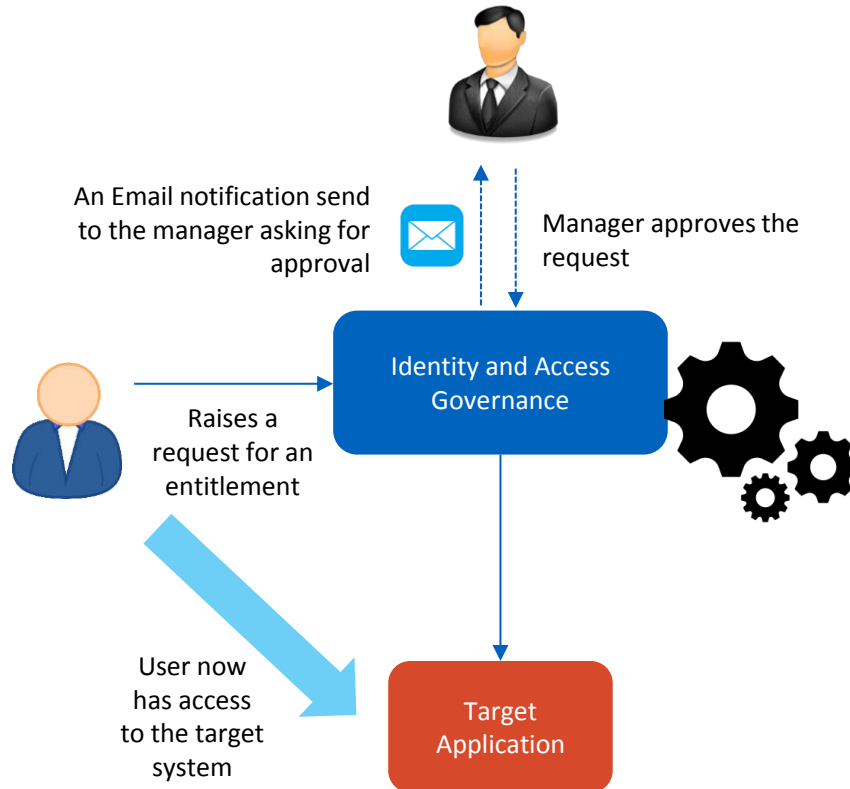


Self Access Request



Business-friendly "shopping cart" guides users through self-service access request processes and requesting roles and entitlements

Self Access Request



Access Requests for which the user role is entitled for could be provisioned automatically through IdM,
While access request he/she is not entitled for would require approval from manager for which workflows can be scripted in IdM

4. Self Service - Profile Management



TATATATAT
TATATATAT



IdM offers controls using which a user can manage/update personal info like email address or phone numbers without raising tickets

5. IAG Key Products in Market



IAG Key Products



Source: Gartner (January 2015)

Vendor	Tool
SailPoint	Sailpoint Identity IQ 6.4
Oracle	Oracle Identity Governance 11gR2 PS3
IBM	IBM Security Identity Manager 7.0.0.2
NetIQ	Identity Manager 4.5 SP1
Dell	Dell One Identity Manager 7.0
CA Technologies	CA IdentityMinder
Hitachi ID	Hitachi ID Identity Manager 8.2.2

Directory Services



1. Directory Services Overview



Directory Services - Definition

- A data registry used to store network, user, computer, server related data in any enterprise architecture
- Stores the data in a Directory Information Tree (DIT) which contains descriptive, attribute-based and hierarchical storage
- Forms a foundation for enterprise eBusiness applications
- Supports sophisticated filtering and searching capabilities
- Optimized to give quick responses to high volume lookup / search operations
- Accessible using any of the below communication protocol:
 - Lightweight Directory Access Protocol – LDAP
 - Directory Services Markup Language – DSML

Directory Services Vs. Database

Directory Services	Databases (RDBMS)
Data storage in DIT forms a reliable, efficient and quicker for Data Management	Data storage in Relational Database tables makes inefficient and poorer in performance for
One Directory services entry can contain multiple information related to different data model (Example is Multi-valued attributes)	Need to have multiple tables with linkages to represent the same data
With the help of Inheritance, the data storage can be extended to any extent	No Such inheritance possible
DN forms the primary key which makes data Management quick and easy	Usage of Primary / foreign key combination across multiple tables becomes inefficient
Data Lookup / Search is very fast and reliable	Database Search is much slower and resource intensive
Search – Quick Write – Bit slower compared to RDBMS	Search – Slower Write - Quick
Faster replication with secondary Directory services	Slower Replication with secondary Databases

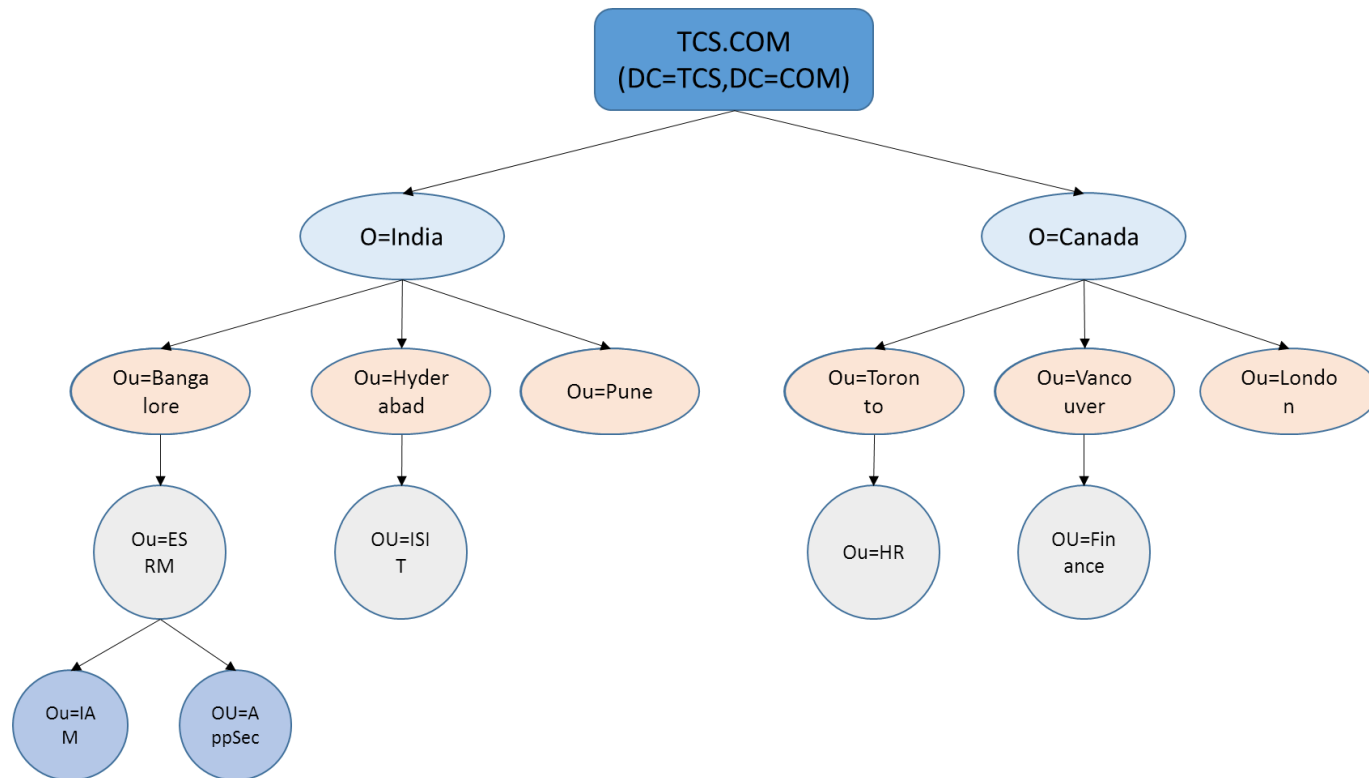
2. LDAP - Introduction and Concepts



LDAP – Introduction and Concepts

- LDAP is a common language / protocol used by servers and clients to communicate with Directory Services
- LDAP is lightweight version of Directory Access Protocol which in turn inherits the standards of X-500 defined by ISO / ITU and runs over TCP/IP
- The current running LDAP version is v3 and all the directory services in industry supports LDAP v3
- LDAP v3 Search supports the Equality, Inequality, Substring, Approximate match (for phonetic matching), greater than, less than, Boolean combinations of the previous filters using the and (&), or (|), and not (!) operators
- For exchange of directory information between the servers, LDAP uses LDAP Data Interchange Format (LDIF)

Typical LDAP Directory Information Tree (DIT) Structure



LDAP Terminologies

Terminology	Description
Suffix	A suffix is a branch or subtree of DIT used for Data Management
Attributes	An attribute is a descriptive information about an entry. For example, User ID (uid), First Name (givenname), Last Name (sn) etc.
Object Class	Collection of attributes / attribute container
OID	Unique Identifier used for defining the objectclass
Indexing	Concept of notifying directory server to prioritize the entries during search which has indexed attributes
Schema	Combination of attributes and objectclasses forms the Directory Server schema
Organization	Logical component of DIT which is useful in defining the tree structure and forms important role in forming DN
Organizational Units	
Distinguished Name	Similar to Primary key in Directory server and every LDAP entry is referenced using DN
Relational Distinguished Name	Name of the LDAP Server Entry. This is a substring of Distinguished Name

3. Directory Services – Server Replication, Types and Vendors



Directory Server Replication

- In a typical production environment, the business critical applications configured with Directory servers as backend needs High Availability during the fail-overs. To cover these fail-overs, Directory servers are often configured for replication so that the directory data coming from application is not lost
- Typically, there are two kinds of replication setup possible:
 - **Master – Master Replication:** Here, both the directory servers acts as master and receives the data together from application. This setup is more suitable when multi node application is load-balanced and the traffic can route to any instance of application
 - **Master – Slave Replication:** Here, master directory server receives the data from application and syncs up the slave directory server. This synchronization may be in a real time or may be a scheduled process. During the fail-over situations, the slave directory server needs to be manually configured as master.

Types of Directory Services

- There are three types of directory services:
 - **Global Directory Services:** These forms the single point of information for the enterprise level applications which needs to be configured.
 - **Meta Directory Services:** In an enterprise architecture, if the data is flowing from n number of data stores towards Global Directory services, then a logical stopover to aggregate the data forms meta directory services. This meta directory server would transform the data to the required format as that of Global Directory Services
 - **Virtual Directory Services:** In an enterprise architecture, if large number of applications access the Global Directory Server, the performance and efficiency of data transfer may be affected. In order to overcome this limitation, an abstract layer of data needed for each application can be configured so that the application efficiency can be improved. Virtual directory services can even collect the data from disparate systems for application usage.

Directory Services - Vendors

- Below are some of the vendors who are providing the directory services:
 - Global Directory Services
 - ☐ Active Directory
 - ☐ Apache Directory Server
 - ☐ NetIQ Directory Server
 - ☐ Red Hat Directory Server
 - ☐ Oracle Internet Directory Server
 - ☐ IBM Security Directory Server
 - ☐ Windows NT Directory Server
 - ☐ OpenLDAP
 - Meta Directory Services
 - ☐ NetIQ Metadirectory Services
 - ☐ Microsoft Metadirectory Services
 - ☐ SunOne Metadirectory Services
 - Virtual Directory Services
 - ☐ Microsoft Virtual Directory Services
 - ☐ Oracle Virtual Directory Services

Role Management



1. Role Engineering



Role Engineering and Management

Role Engineering is the process of defining roles, permissions, constraints and role-hierarchies

- Role Engineering is the process of defining Roles in an Organization to manage the user access or privileges.
- Every application access depends on roles or groups.

Role Management is the combination of discovery, design, engineering, optimization and lifecycle management of roles and related rules.

- Role Management is the process of managing the roles and integrating it with the identity management system.
- Role Management also includes certifying or validating roles at regular intervals.

Role Based Access Control is the concept where the roles are defined at an organization level and then the access to the resources are mapped to these roles.

Role Based Access Control

- Concept was pioneered in 1970

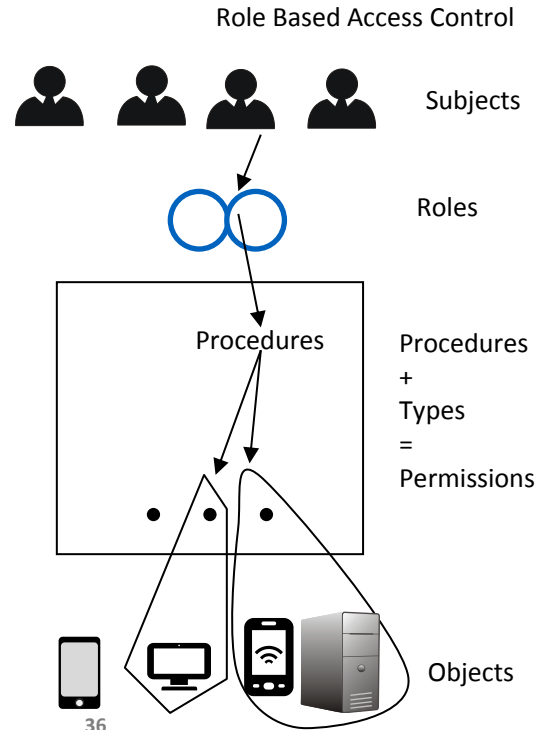
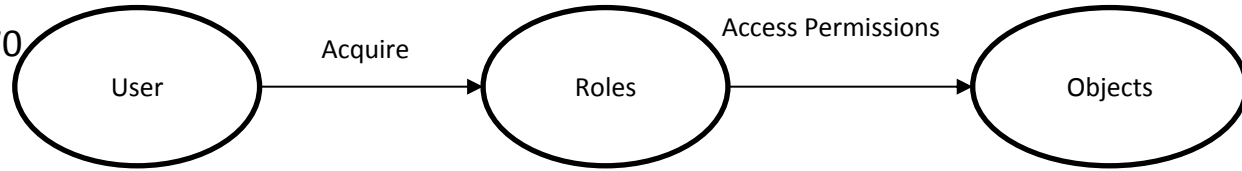
- Security Principles

- Least Privilege
- Separation of duties
- Data Abstraction

- Components

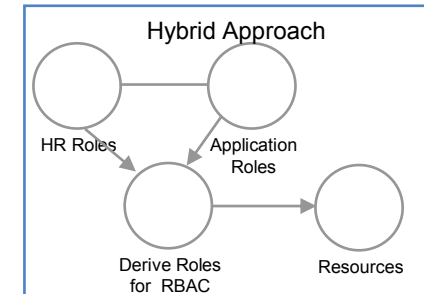
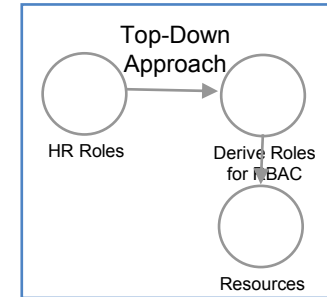
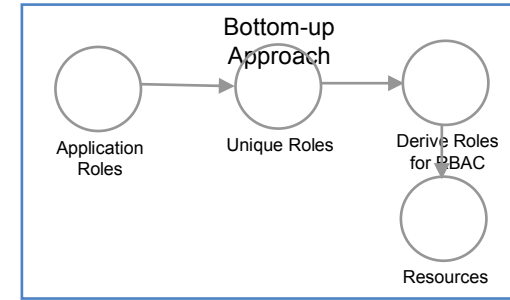
- Subjects
- Role
- Permission
- Objects

Roles: Developer, HR, Sales, Business, CEO

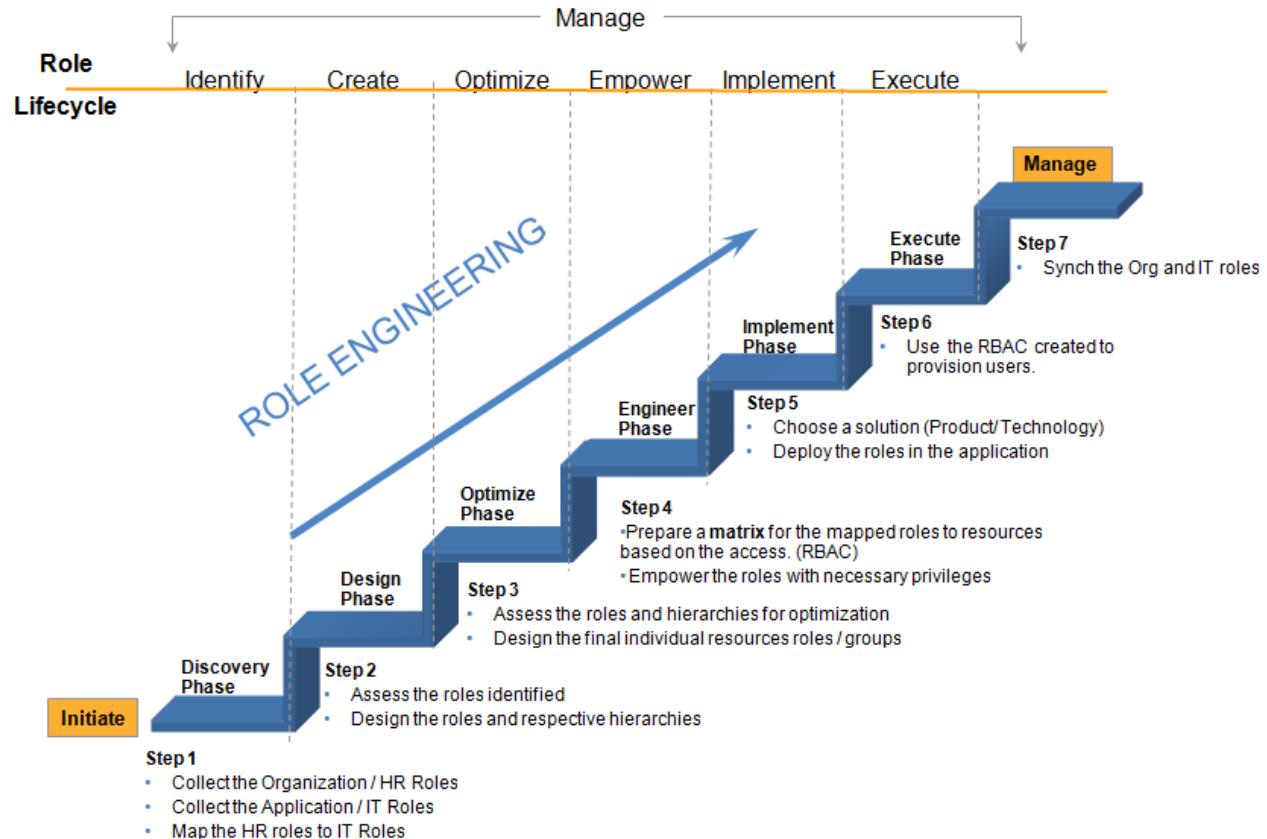


Role Engineering Approaches

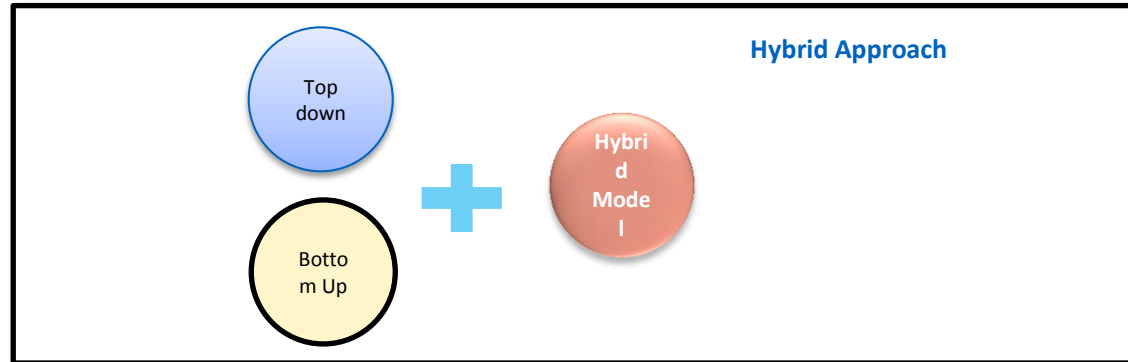
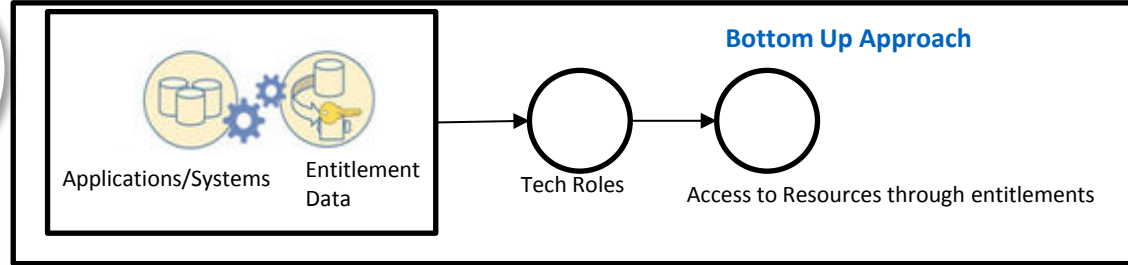
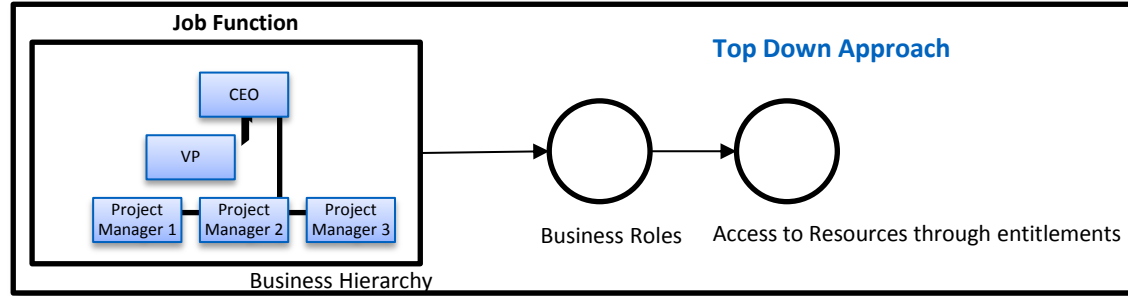
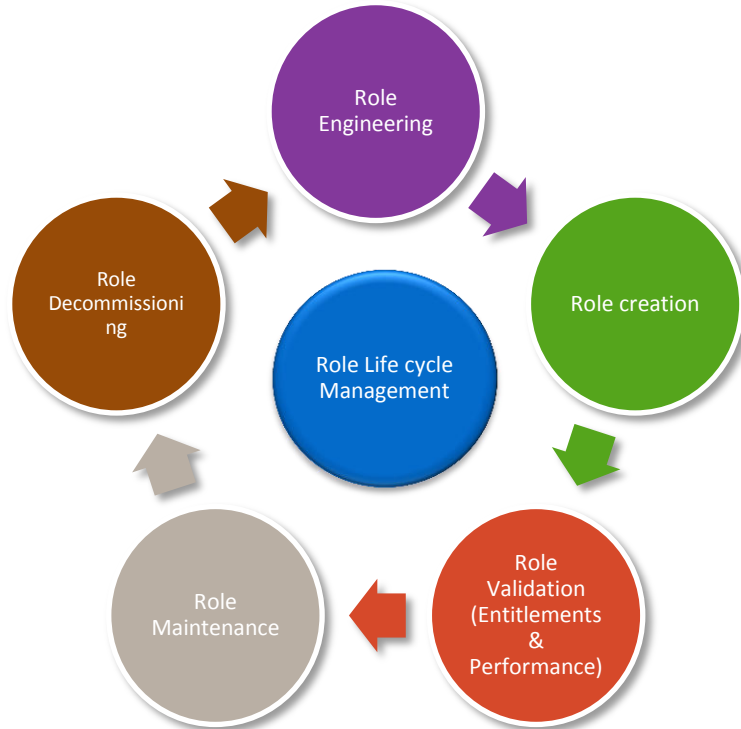
- There are 3 basic approaches for Role Engineering
 - Bottom up which derives roles from the groups and permissions defined on the existing systems and platforms in the enterprise.
 - Top Down which derives roles from an analysis of business function and organizational criteria, typically from a “zero base” starting point.
 - Hybrid which, as the name implies, derives roles using a combination of bottom up and top down approaches.



Role Engineering Methodology



Role Management & Engineering



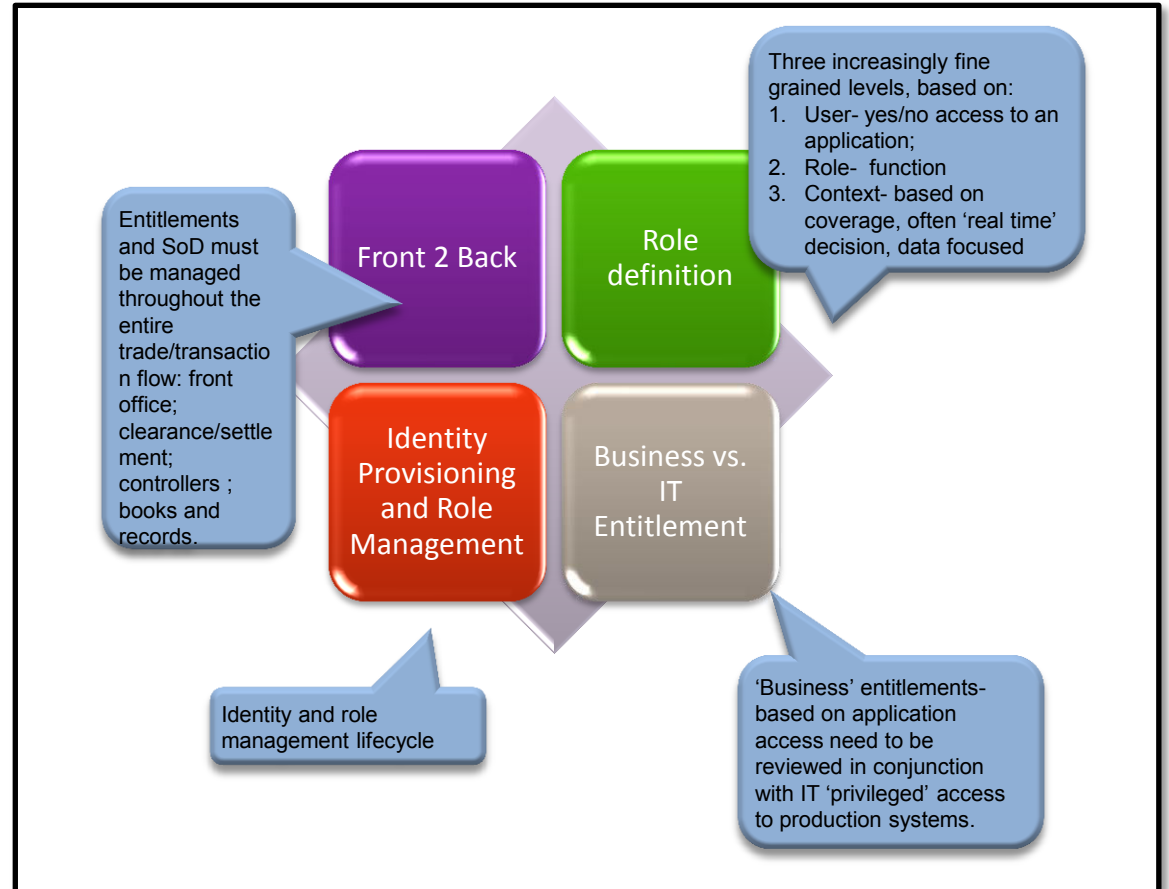
2. Entitlement Management



Entitlements Management – Four Cornerstones

Effective entitlement management relies on four cornerstones:

1. Defining roles and SoD requirements;
2. Managing identities and roles;
3. Looking at SoD through the business;
4. Understanding both business and IT entitlements.



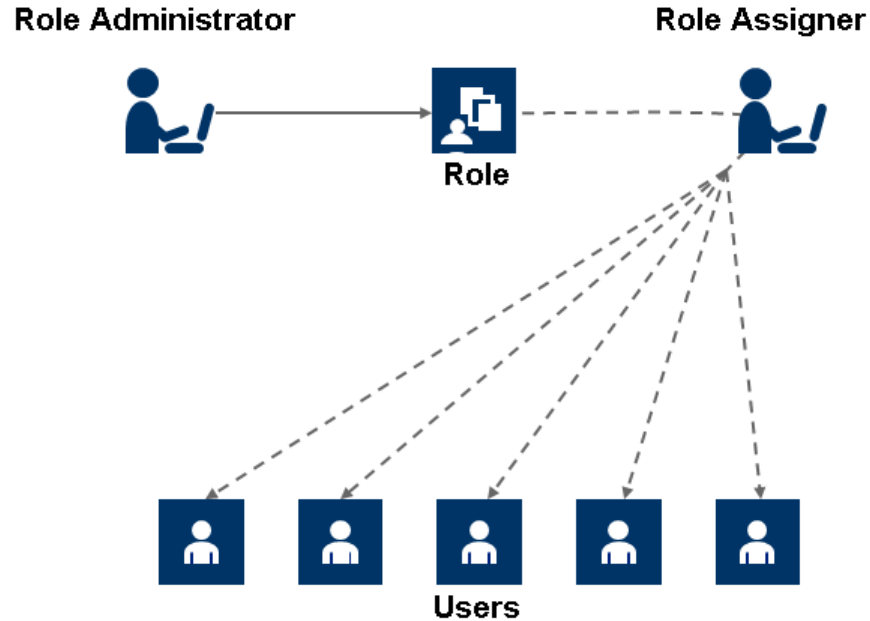
TATATATAT
TATATATAT



3. Segregation of Duties

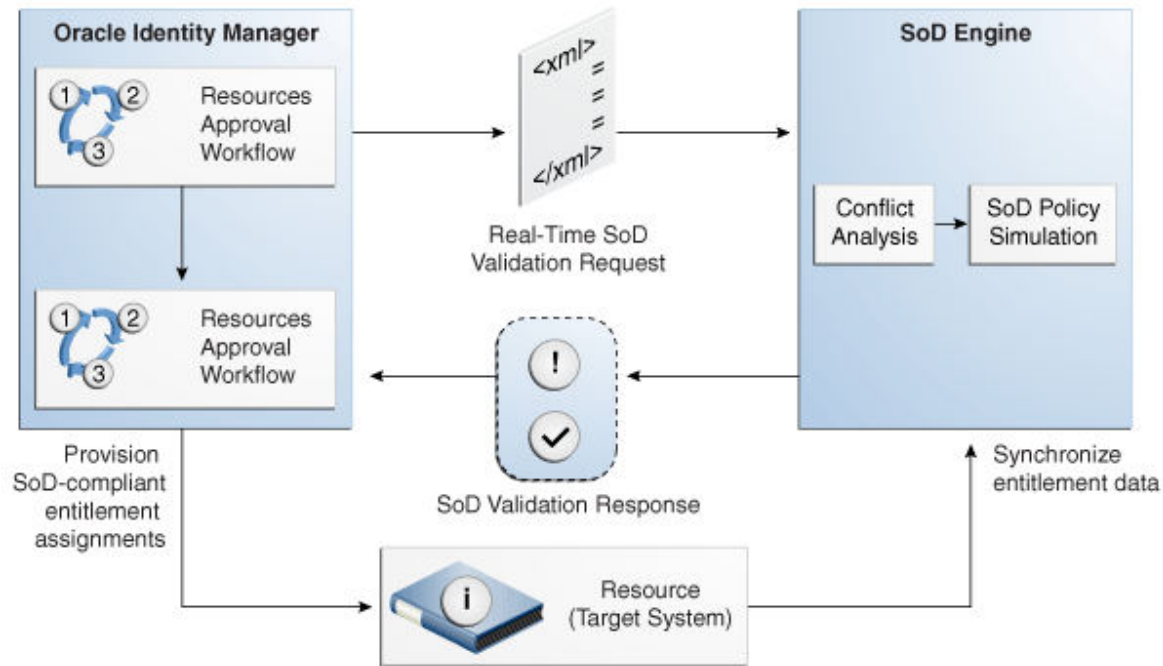


Segregation of Duties (SoD)



The concept of Segregation of Duties (SoD) is aimed at applying checks and balances on business processes. Each stage of a business process may require the involvement of more than one individual. An organization can convert this possibility into a requirement for all IT-enabled business processes by implementing SoD as part of its user provisioning solution.

Segregation of Duties



The SoD validation process in IG occurs when a user creates a request for an entitlement on a particular target system. The request is funneled through a resource approval workflow and, if it passes that initial workflow, a resource provisioning workflow.

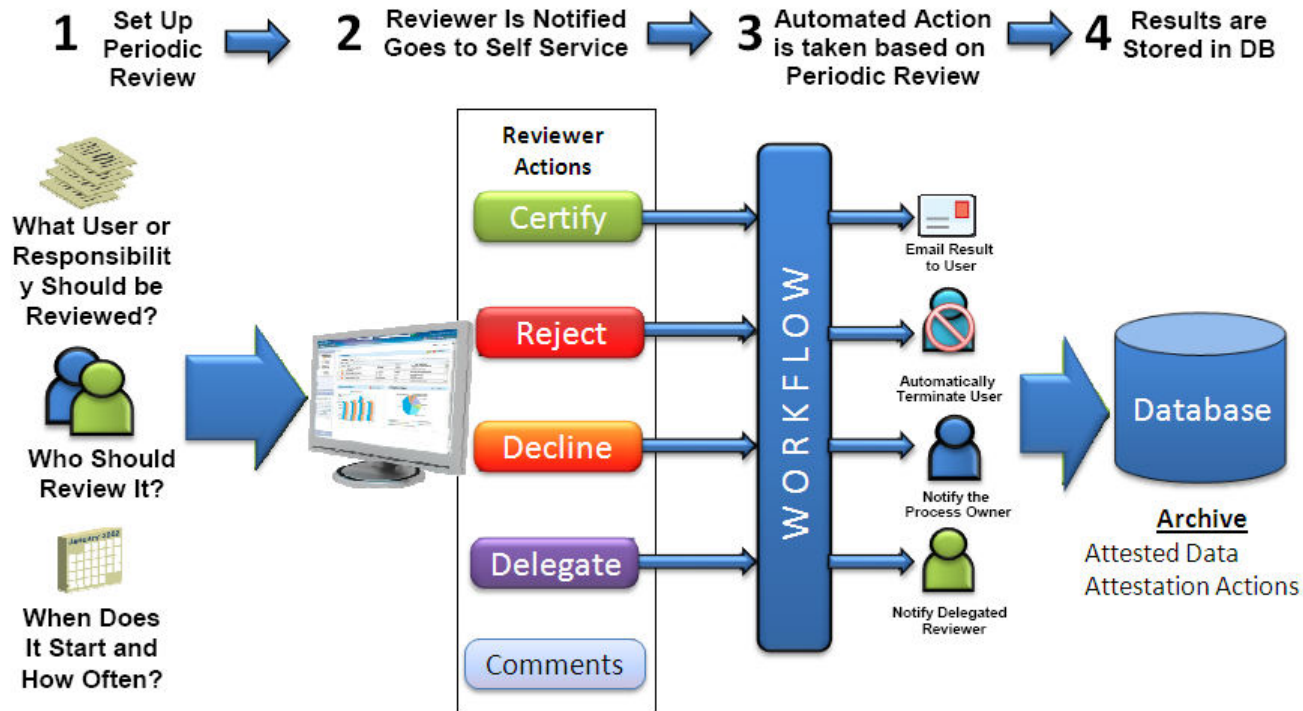
4. Access Re/Certification





Access Recertification is the process of gathering user access rights and doing comparative analysis to determine if the access rights are valid and/or necessary. This audit function is used with an enterprise provisioning system to provide a feedback loop necessary to ensure the provisioning system is correctly granting access.

Access Re/Certification



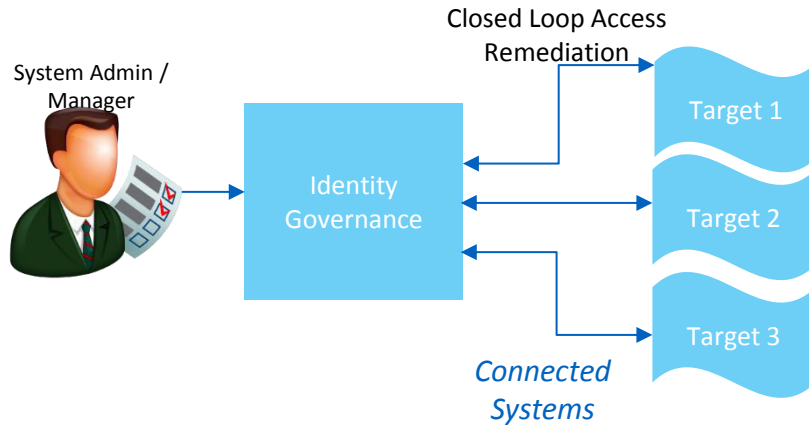
5. Access Remediation



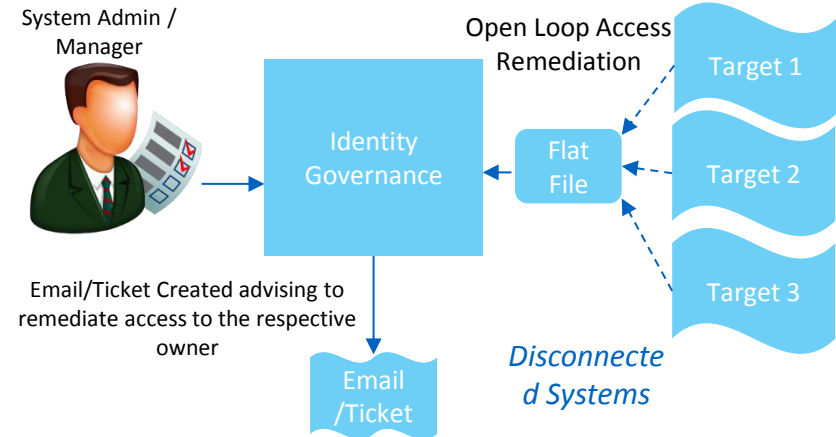
Access Remediation

Access Remediation is the means by which clients with a non-compliant Access state are brought to a compliant state

Closed Loop Access Remediation



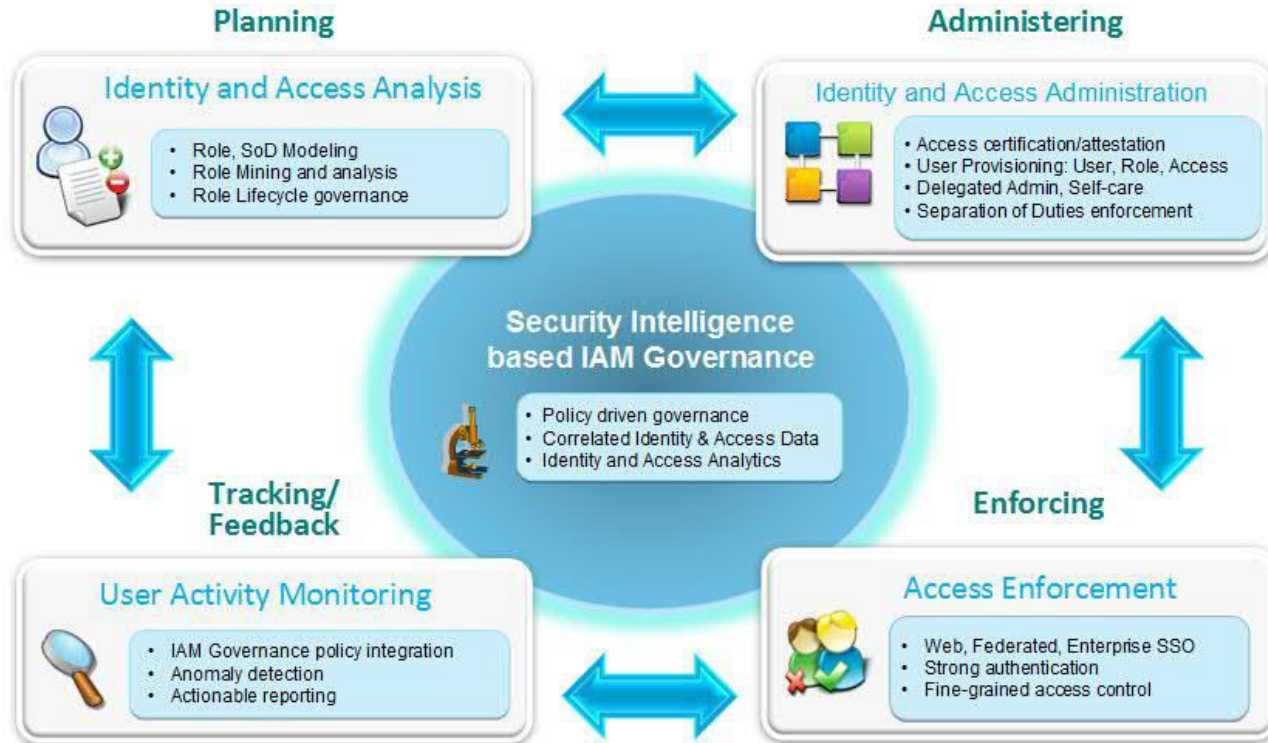
Open Loop Access Remediation





Organization undergo audit periodically and are responsible to providing details around who has access to what and whether relevant access are provided based on the User role

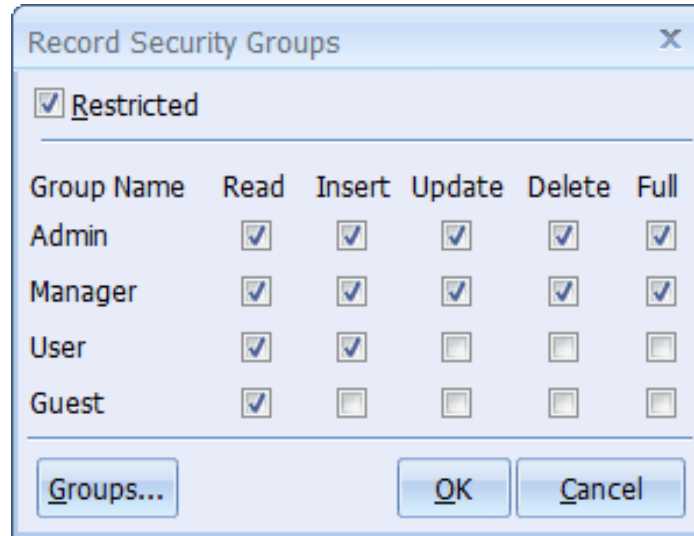
Access Remediation Process



6. Access Provisioning Models



Access control List (ACL)

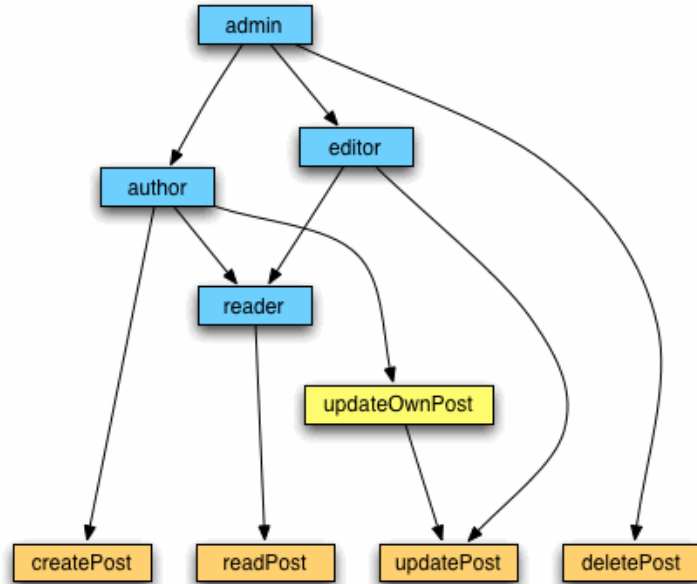


A screenshot of a Windows-style dialog box titled "Record Security Groups". At the top, there is a checkbox labeled "Restricted" which is checked. Below this is a table with five columns: "Group Name", "Read", "Insert", "Update", "Delete", and "Full". The rows represent different user groups: "Admin", "Manager", "User", and "Guest". Each cell in the table contains a checkbox. The "Admin" and "Manager" groups have all permissions checked. The "User" group has "Read" and "Insert" checked, while "Update", "Delete", and "Full" are unchecked. The "Guest" group has only "Read" checked, with "Insert", "Update", "Delete", and "Full" unchecked. At the bottom of the dialog, there are three buttons: "Groups...", "OK", and "Cancel".

Group Name	Read	Insert	Update	Delete	Full
Admin	☒	☒	☒	☒	☒
Manager	☒	☒	☒	☒	☒
User	☒	☒	☐	☐	☐
Guest	☒	☐	☐	☐	☐

With **Access Control Lists**, once a user is authenticated, that user is allowed to access an application or not depending on whether that user's id is on a list of authorized users (white list) or blocked users (black list). This mode is either all-in or all-out. It is extremely coarse-grained

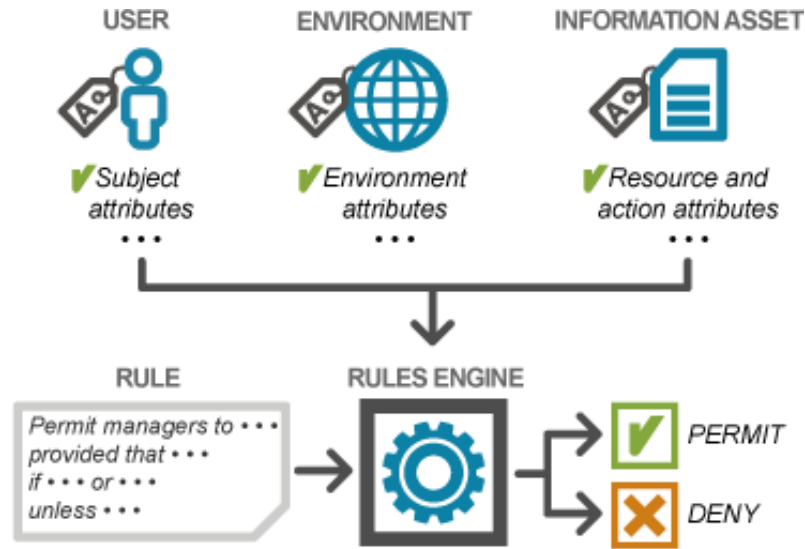
Role Based Access Control (RBAC)



WordPress lets users define roles and associate permissions to roles and then roles to users therefore transitively granting users permissions.

Role-based access control (RBAC) is a method of regulating access to computer or network resources based on the roles of individual users within an enterprise. In this context, access is the ability of an individual user to perform a specific task, such as view, create, or modify a file.

Attribute Based Access Control (ABAC)



Attribute Based Access Control (ABAC) is an access control model wherein the access control decisions are made based on a set of characteristics, or attributes, associated with the requester, the environment, and/or the resource itself. Each attribute is a discrete, distinct field that a policy decision point can compare against a set of values to determine whether or not to allow or deny access.

Thank You

